

A03 — ADMINISTRACIÓN DE RIESGOS

1. Datos Generales

Campo	Información
Nombre de la empresa / organización	Clínica Privada
Rubro / Industria	Salud / Atención médica privada
Tamaño	120 empleados / aproximadamente 800 pacientes diarios
Alumno(s) / Grupo	Julian Greco
Legajo(s)	
Fecha de elaboración	09/09/2026
Responsable del análisis	Responsable de Seguridad de la Información

2. Objetivo y Alcance del Análisis

Objetivo

El objetivo del presente análisis es identificar, evaluar y tratar los principales riesgos de seguridad de la información que afectan a una clínica privada, considerando la confidencialidad, integridad y disponibilidad de los sistemas y de la información utilizada para la atención de pacientes y para la gestión administrativa.

El análisis busca establecer una valoración inicial de los riesgos, proponer salvaguardas adecuadas y determinar el nivel de riesgo residual esperado luego de la implementación de las medidas de tratamiento.

Alcance

El análisis comprende los sistemas, información e infraestructura tecnológica relacionados con:

- Historias clínicas digitales.
- Información personal y médica de pacientes.
- Información de obras sociales.
- Información de facturación.
- Cuentas y credenciales de usuarios.
- Sistemas clínicos y administrativos.
- Servidores y almacenamiento.
- Red interna.
- Infraestructura tecnológica crítica.

- Personal que utiliza los sistemas de información.

Se considera el entorno de una clínica privada de aproximadamente 120 empleados y una atención aproximada de 800 pacientes diarios.

3. Inventario y Clasificación de Activos

ID	Descripción del Activo	Tipo	Responsable	Clasificación	Criticidad
A01	Sistema de historias clínicas digitales	Software	Director de Sistemas	Restringida	Alta
A02	Historias clínicas e información médica de pacientes	Información	Director Médico	Restringida	Alta
A03	Base de datos de pacientes y obras sociales	Información	Responsable de Sistemas	Confidencial	Alta
A04	Información de facturación y administración	Información	Responsable Administrativo	Confidencial	Alta
A05	Cuentas y credenciales de usuarios	Información	Responsable de Seguridad de la Información	Restringida	Alta
A06	Servidores y sistemas de almacenamiento	Hardware	Director de Sistemas / Infraestructura	Interna	Alta
A07	Red interna e infraestructura de comunicaciones	Red	Responsable de Infraestructura	Interna	Alta
A08	Personal de la clínica	Humano	Recursos Humanos / Responsables de área	Interna	Media

Nota: La clasificación corresponde a la sensibilidad de la información o al carácter interno del activo. Las historias clínicas y las credenciales se consideran de clasificación **Restringida** debido a las consecuencias que tendría su exposición o uso indebido.

4. Identificación de Amenazas y Vulnerabilidades

ID	Activo (ID)	Descripción de la Amenaza	Tipo	Vulnerabilidad Asociada
T01	A01, A02, A06	Ataque de ransomware que cifra o bloquea los sistemas e información clínica	Intencional	Falta de backups offline/inmutables, posibles vulnerabilidades sin actualizar, dependencia de sistemas digitales y exposición a malware/phishing
T02	A01, A02, A05	Acceso no autorizado a historias clínicas mediante credenciales válidas	Intencional	Permisos excesivos, ausencia o cobertura insuficiente de MFA y controles de acceso insuficientemente revisados
T03	A01, A06, A07	Falla de infraestructura, software, almacenamiento o conectividad que provoque indisponibilidad	Accidental	Falta de redundancia, monitoreo insuficiente y procedimientos de contingencia no completamente formalizados
T04	A05, A01, A04, A08	Phishing o ingeniería social para obtener credenciales o instalar malware	Intencional	Capacitación insuficiente, exposición de usuarios a correos maliciosos y controles antiphishing mejorables
T05	A02, A03, A04	Fuga o exposición accidental o intencional de información sensible	Accidental / Intencional	Controles de acceso mejorables, ausencia de controles completos de prevención de fuga y posibles errores humanos
T06	A01, A02	Modificación no autorizada de información clínica	Intencional	Privilegios excesivos, falta de separación de funciones y necesidad de fortalecer auditoría y monitoreo de modificaciones
T07	A06, A07	Incendio, pérdida de agua o inundación que afecte la infraestructura tecnológica	Natural / Accidental	Dependencia de infraestructura física, protección ambiental limitada y necesidad de contar con backups fuera del sitio

5. Escalas de Valoración

5.1 Escala de Probabilidad

Valor	Nivel	Descripción
1	Raro	El evento solo ocurriría en circunstancias excepcionales.
2	Improbable	Podría ocurrir, pero no se espera que suceda.
3	Posible	Existe una posibilidad real de que ocurra.
4	Probable	Es muy probable que ocurra en algún momento.
5	Casi seguro	Se espera que ocurra frecuentemente / ha ocurrido recientemente.

5.2 Escala de Impacto

Valor	Nivel	Descripción
1	Insignificante	Impacto mínimo, sin consecuencias operativas ni económicas relevantes.
2	Menor	Alteración leve de la operación, costo bajo.
3	Moderado	Impacto operativo y económico apreciable, recuperable.
4	Mayor	Impacto significativo, pérdida de operación o datos, costo alto.
5	Catastrófico	Paralización total, pérdida crítica de datos, daño reputacional o legal severo.

6. Matriz de Calor

Se utiliza la matriz de riesgo definida en la plantilla, calculando:

Riesgo = Probabilidad × Impacto

Los niveles se clasifican de la siguiente manera:

Nivel	Rango	Acción requerida
Bajo	1–4	Monitorear. Puede aceptarse.
Medio	5–9	Plan de acción a mediano plazo.
Alto	10–15	Tratamiento prioritario a corto plazo.
Crítico	16–25	Acción inmediata. Escalar a dirección.

7. Evaluación de Riesgos

ID	Activo	Amenaza	Prob.	Impacto	Valor	Nivel	Justificación breve
R01	A01, A02, A06	T01 — Ransomware	4	5	20	Crítico	La elevada dependencia de los sistemas digitales y la posibilidad de ingreso de malware mediante phishing, vulnerabilidades o credenciales comprometidas hacen probable el evento. El impacto sería catastrófico debido a la posible interrupción de las

ID	Activo	Amenaza	Prob.	Impacto	Valor	Nivel	Justificación breve
							historias clínicas y de la atención de aproximadamente 800 pacientes diarios.
R02	A01, A02, A05	T02 — Acceso no autorizado	4	5	20	Crítico	La clínica posee múltiples usuarios que requieren acceso a información clínica. Una gestión inadecuada de permisos o el compromiso de credenciales podría permitir accesos indebidos. El impacto es catastrófico por la sensibilidad de las historias clínicas.
R03	A01, A06, A07	T03 — Indisponibilidad	3	5	15	Alto	Las fallas de hardware, software, almacenamiento o conectividad son posibles. Una interrupción prolongada afectaría la atención médica y podría obligar a utilizar procedimientos manuales.
R04	A05, A01, A04, A08	T04 — Phishing	4	4	16	Crítico	Los 120 empleados representan una superficie de exposición relevante. El compromiso de una cuenta podría facilitar accesos indebidos y ataques posteriores, incluido ransomware.
R05	A02, A03, A04	T05 — Fuga de información	3	5	15	Alto	La cantidad de usuarios y procesos que manipulan información sensible genera posibilidades de errores humanos, uso indebido o divulgación accidental. La exposición de datos médicos y personales tendría consecuencias legales, económicas y reputacionales severas.

ID	Activo	Amenaza	Prob.	Impacto	Valor	Nivel	Justificación breve
R06	A01, A02	T06 — Alteración de información clínica	3	5	15	Alto	Para modificar información se requiere acceso al sistema. La existencia de múltiples usuarios y la sensibilidad de la información justifican una probabilidad posible. El impacto sería catastrófico porque una modificación podría afectar diagnósticos, tratamientos o antecedentes médicos.
R07	A06, A07	T07 — Incendio o inundación	2	5	10	Alto	Estos eventos son menos frecuentes que las amenazas informáticas, pero pueden afectar físicamente servidores, almacenamiento y redes. El impacto sería catastrófico si se interrumpen los servicios y también se ven comprometidas las copias de seguridad.

8. Tratamiento de Riesgos y Riesgo Residual

Se selecciona principalmente la estrategia **Mitigar**, debido a que los riesgos identificados pueden reducirse mediante controles técnicos, físicos y administrativos sin necesidad de discontinuar las actividades de la clínica.

Riesgo	Estrategia	Salvaguardas propuestas	Tipo salv.	Pro b. resid.	Imp. resid.	Val. resid.	Nivel resid.
R01 — Ransomware	Mitigar	Backups offline/inmutables; MFA; actualización de sistemas; segmentación de red; protección de endpoints;	Técnica / Administrativa	2	5	10	Alto

Riesgo	Estrategia	Salvaguardas propuestas	Tipo salv.	Pro b. resid.	Imp. resid.	Val. resid.	Nivel resid.
R02 — Acceso no autorizado	Mitigar	MFA; mínimo privilegio; revisión periódica de permisos; eliminación de cuentas desvinculadas; cuentas individuales; monitoreo de accesos	Técnica / Administrativa	2	5	10	Alto
R03 — Indisponibilidad	Mitigar	Monitoreo de infraestructura; redundancia de componentes críticos; procedimientos de contingencia; pruebas de recuperación; definición de RTO/RPO	Técnica / Administrativa	2	5	10	Alto
R04 — Phishing	Mitigar	Capacitación periódica; simulaciones de phishing; MFA; filtros antispam/antiphishing; mecanismos de reporte	Técnica / Administrativa	2	4	8	Medio
R05 — Fuga de información	Mitigar	Clasificación de información; controles de acceso; cifrado; monitoreo de accesos y transferencias; medidas de prevención de fuga; capacitación	Técnica / Administrativa	2	5	10	Alto
R06 — Alteración de información clínica	Mitigar	Mínimo privilegio; separación de funciones; registros de auditoría; registro de	Técnica / Administrativa	2	5	10	Alto

Riesgo	Estrategia	Salvaguardas propuestas	Tipo salv.	Pro b. resid.	Imp. resid.	Val. resid.	Nivel resid.
		modificaciones; revisión de permisos; detección de modificaciones anómalas					
R07 — Incendio/inundación	Mitigar	Backups fuera del sitio; sensores de humo, temperatura y agua; protección contra incendios; evaluación de instalaciones; ubicación protegida de equipos; infraestructura alternativa	Física / Técnica / Administrativa	1	5	5	Medio

Fundamentación del riesgo residual

El riesgo residual representa la exposición que permanecería luego de implementar las salvaguardas propuestas. Las medidas reducen principalmente la **probabilidad de ocurrencia**, mientras que en determinados casos también disminuyen el impacto mediante mecanismos de recuperación y continuidad.

No se considera apropiado llevar todos los riesgos a nivel bajo, dado que persiste un riesgo inherente a la operación de sistemas digitales, al tratamiento de información médica sensible y a la dependencia de infraestructura tecnológica.

Los riesgos R01, R02, R03, R05 y R06 permanecen en nivel alto debido principalmente a que sus impactos potenciales continúan siendo elevados aun después de implementar controles.

9. Resumen de Resultados

Riesgo inherente

Nivel	Cantidad de riesgos	% del total
Crítico	3	42,86 %
Alto	4	57,14 %
Medio	0	0 %
Bajo	0	0 %
Total	7	100 %

Los riesgos críticos son:

- R01 — Ransomware sobre sistemas de historias clínicas.
- R02 — Acceso no autorizado a historias clínicas.
- R04 — Phishing y robo de credenciales.

Los riesgos altos son:

- R03 — Indisponibilidad del sistema de historias clínicas.
- R05 — Fuga de información de pacientes y obras sociales.
- R06 — Alteración no autorizada de información clínica.
- R07 — Incendio o inundación de infraestructura tecnológica.

Riesgo residual esperado

Nivel	Cantidad de riesgos	% del total
Crítico	0	0 %
Alto	5	71,43 %
Medio	2	28,57 %
Bajo	0	0 %
Total	7	100 %

La aplicación de las salvaguardas propuestas permite reducir la totalidad de los riesgos críticos a niveles inferiores. Sin embargo, cinco riesgos permanecen en nivel alto debido a la elevada criticidad de los activos involucrados y al impacto potencial sobre la atención médica y la información de los pacientes.

10. Conclusiones y Recomendaciones

El análisis realizado identifica una exposición significativa a riesgos de seguridad de la información en la clínica. Los resultados muestran que los principales riesgos están relacionados con ransomware, acceso no autorizado, phishing, indisponibilidad de los sistemas y exposición o alteración de información clínica.

La criticidad de estos riesgos se encuentra directamente relacionada con la dependencia de los sistemas digitales para la atención de aproximadamente 800 pacientes diarios y con la sensibilidad de las historias clínicas, información personal, datos de obras sociales y datos de facturación.

Se recomienda priorizar las siguientes acciones:

1. **Implementar una estrategia de backups resilientes**, incluyendo copias offline o inmutables y pruebas periódicas de restauración.
2. **Implementar MFA en sistemas críticos**, especialmente para cuentas administrativas y usuarios con acceso a información clínica.
3. **Fortalecer la capacitación contra phishing** y realizar simulaciones periódicas para los aproximadamente 120 empleados.
4. **Aplicar el principio de mínimo privilegio** y realizar revisiones periódicas de los permisos de acceso.
5. **Fortalecer los mecanismos de auditoría y monitoreo** sobre accesos y modificaciones de historias clínicas.
6. **Establecer procedimientos formales de continuidad y recuperación**, incluyendo objetivos RTO/RPO y pruebas periódicas.
7. **Mejorar la protección física de la infraestructura tecnológica** y mantener copias de seguridad fuera del sitio.

Como conclusión, la estrategia recomendada es **mitigar los riesgos mediante una combinación de salvaguardas técnicas, físicas y administrativas**, manteniendo un proceso periódico de revisión y actualización de la matriz de riesgos.

El tratamiento debe ser supervisado por los responsables de Seguridad de la Información, Sistemas, Infraestructura y las áreas propietarias de los activos, con seguimiento de los avances por parte de la dirección.